

GRC104: The "GlobalSync Inc." Compliance Crisis

NAME: JOY ORILADE

DATE: 7TH MAY 2026

INSTRUCTOR: COMM IDRIS AMINU

Exercise Goal: To test your comprehensive understanding of compliance frameworks, audit processes, data privacy laws, and the legal implications of non-compliance in a realistic, high-stakes scenario.

Total Points: 100

Target: Achieve a 70% (70 points) or higher to successfully "save" the company.

Scenario Introduction:

Welcome, newly appointed **Chief Compliance Officer (CCO)**. You have just been hired by **GlobalSync Inc.**, a fast-growing multinational technology company headquartered in California, with significant operations in the European Union and Brazil.

GlobalSync's core product is a cloud-based collaboration platform used by businesses worldwide. The company has experienced rapid growth, but its compliance programs have not kept pace. The Board of Directors has hired you following a tip from a whistleblower about potential serious compliance failures. They are nervous, as a major merger with a European company is scheduled in six months, and any significant compliance issues could derail the deal.

Your Mission: Conduct a rapid but thorough compliance assessment, manage the immediate crisis, and present a strategic remediation plan to the Board.

Part 1: The Initial Discovery & Risk Triage (25 Points)

Task 1.1: The Whistleblower Email (10 Points)

You receive an anonymous email from an employee with the following allegations:

- **Allegation A:** Customer data from EU clients is being transferred to and processed in GlobalSync's main US data center without a proper legal mechanism.
- **Allegation B:** The sales team in Brazil has been offering significant "incentives" to secure large government contracts.
- **Allegation C:** There is no centralized process for handling customer requests to delete their data, and many requests are ignored or lost.
- **Allegation D:** The company cannot reliably prove that its financial reporting controls are effective.

Your Questions:

For each allegation (A, B, C, D), identify:

- **The Primary Regulation/Framework at Risk** (e.g., GDPR, SOX, FCPA, etc.).
- **The Potential Legal Implication** (e.g., Financial Penalty, Criminal Liability, Civil Lawsuit, Administrative Action).
- **The "Key Dimension" of this Non-Compliance** (Is it Intentional/Unintentional? Systemic/Isolated?).

ANSWER

Allegation	Primary Regulation/Framework at Risk	Potential Legal Implication	Key Dimension of Non-Compliance
Allegation A: Customer data from EU clients is being transferred to and processed in GlobalSync's main US data center without a proper legal mechanism.	General Data Protection Regulation (GDOR)	Administrative fines, regulatory investigations, suspension of international data transfers, reputational damage, civil lawsuits from affected customers	Likely Systemic because it affects international data operations across the organization. Could be Unintentional if caused by poor governance, but regulators may view continued non-compliance as negligent.
Allegation B: The sales team in Brazil has been offering significant "incentives" to secure large government contracts.	Foreign Corrupt Practices Act (FCPA), Brazil Anti-Corruption Law	Criminal liability, anti-bribery investigations, heavy financial penalties, contract termination, imprisonment for individuals involved, reputational damage	Potentially Intentional because incentives/bribes are deliberate actions. Also likely Systemic if sales culture or management encouraged unethical practices.
Allegation C: There is no centralized process for handling customer requests to delete their data, and many requests are ignored or lost.	General Data Protection Regulation (GDOR), California Consumer Privacy Act (CCPA)	Regulatory fines, customer complaints, civil litigation, compliance audits, enforcement actions from privacy regulators	Primarily Systemic because the organization lacks a formalized process. Most likely Unintentional, resulting from weak compliance management and inadequate operational controls.

Allegation D: The company cannot reliably prove that its financial reporting controls are effective	Sarbanes-Oxley Act (SOX)	SEC investigations, financial penalties, failed audits, shareholder lawsuits, loss of investor confidence, executive liability	Likely Systemic because it affects enterprise-wide financial reporting controls. Could become Intentional if management knowingly ignored control weaknesses or submitted inaccurate reports.
--	--------------------------	--	---

Task 1.2: Risk Assessment Matrix (15 Points)

Using the risk matrix methodology from the audit course, create a 5x5 Risk Matrix (Likelihood: Rare, Unlikely, Possible, Likely, Almost Certain; Impact: Insignificant, Minor, Moderate, Major, Catastrophic).

Plot each of the four allegations (A, B, C, D) on your matrix. Justify your placement for each one based on the potential financial, legal, and reputational impact to GlobalSync.

ANSWER

Allegation	Likelihood	Impact	Risk Level	Justification
A: EU-US Data	Likely	Major	High	High probability of regulatory scrutiny (CNIL) and potential for massive GDPR fines
B: Bribery	Possible	Catastrophic	Critical	FCPA/DOJ involvement can lead to criminal exposure and immediate termination of the merger.
C: DSR Failures	Almost Certain	Moderate	High	Failure is confirmed in 40% of cases; leads to class-action lawsuits in California (CCPA).
D: Security Gaps	Possible	Major	High	Like the MGM incident, gaps in MFA or segmentation could lead to operational shutdown.

Part 2: The Compliance Audit Deep Dive (35 Points)

The Board has approved your request for an immediate, targeted compliance audit. Your team has assembled initial findings.

Task 2.1: Scoping the Audit (10 Points)

Based on the allegations, outline the **Scope and Objectives** for this audit. Be specific. Which business units, processes, and data flows will you examine? What are the key audit questions you need to answer?

ANSWER

- **Business Units:** IT, HR, Legal/Compliance, and the Brazil Regional Sales Team.
- **Data Flows:** Personal data movement from EU/Brazil servers to California.
- **Audit Questions:** Are data transfer mechanisms legally valid? Are deletion requests tracked in a central log? Do anti-bribery controls exist for third-party agents?.

Task 2.2: Evidence Gathering Plan (15 Points)

For allegation A (Improper EU-US data transfers), describe the specific evidence-gathering techniques you would use. Create a mini-plan:

- **Document Review:** Which 3 specific documents would you request first?
- **Interviews:** Which 3 job roles would you interview, and what are 2 key questions for each?
- **Testing:** Describe a control test you would perform to verify the data transfer mechanism.

ANSWER

A. Document Review

1. Data Processing Agreements (DPAs).
2. Standard Contractual Clauses (SCCs).
3. Transfer Impact Assessments (TIAs).

B. Interviews

1. DPO (Data Protection Officer): "How do we verify sub-processor compliance in the US?".
2. Head of IT: "What technical measures (encryption/anonymization) protect data in transit?"..
3. Legal Counsel: "What is our legal response to the Schrems II ruling?".

C. Testing:

1. Perform a Data Flow Observation to trace a packet of EU user data and verify it is encrypted via TLS 1.3 before leaving the EU jurisdiction.

Task 2.3: Drafting the Audit Finding (10 Points)

Your team has confirmed Allegation C is true. GlobalSync has no formal process for data subject requests (DSRs), and a sample shows 40% of deletion requests were never actioned.

Draft a formal audit finding using the required structure:

- **Condition:** What is the problem? (State the fact)
- **Criteria:** What should be happening? (Quote the relevant law/framework principle)
- **Cause:** Why is this happening? (Root cause analysis)
- **Effect:** What is the impact/risk? (Link to legal/financial/reputational consequences)
- **Risk Rating:** Assign a risk rating (Critical, High, Medium, Low) and justify it.

ANSWER

Condition: GlobalSync does not maintain a formalized process for handling Data Subject Requests (DSRs). Audit testing revealed that approximately 40% of customer deletion requests were not processed or documented.

Criteria: Under GDPR Article 17 and CCPA/CPRA consumer rights provisions, organizations must provide individuals with the right to request deletion of personal data and respond within legally defined timelines.

Cause: The organization lacks:

- A centralized DSR management system
- Defined procedures and ownership responsibilities
- Employee training on privacy obligations
- Monitoring and escalation controls

Rapid organizational growth without corresponding compliance investments contributed to the control failure.

Effect: Failure to process deletion requests exposes GlobalSync to:

- Regulatory fines and enforcement actions
- Civil litigation and class-action lawsuits
- Loss of customer trust
- Reputational damage
- Increased merger-related compliance risk

Risk Rating: Critical

Justification: The issue affects multiple jurisdictions (EU, California, Brazil), violates core privacy rights, and demonstrates systemic compliance failure. The high percentage of unprocessed requests significantly increases regulatory and legal exposure

Part 3: Navigating the Legal & Regulatory Maze (25 Points)

The situation has escalated. You have discovered more information.

Task 3.1: The Regulator Knocks (10 Points)

The French Data Protection Authority (CNIL) has sent a formal inquiry about GlobalSync's EU-US data transfers. They are referencing the **Schrems II** ruling and asking what legal mechanism you are using.

- D. **Question:** What are the possible mechanisms for legal data transfer under the GDPR post-Schrems II? Which one is the most robust, and what must GlobalSync do to implement it?
- E. **Question:** If found in violation, what is the **maximum potential fine** GlobalSync could face from the CNIL under GDPR?

ANSWER

Legal Mechanisms for Data transfers under the GDPR Post-Schrems II

Possible mechanisms include:

- Standard Contractual Clauses (SCCs)
- Binding Corporate Rules (BCRs)
- Explicit user consent
- Adequacy decisions (where applicable)
- Derogations for specific situations

Most Robust: **Binding Corporate Rules (BCRs)**

BCRs are considered highly robust because they establish organization-wide privacy protections approved by EU regulators.

Requirements for Implementation

GlobalSync must:

- Conduct Transfer Impact Assessments (TIAs)
- Implement supplementary safeguards
- Use encryption and access controls
- Document transfer activities
- Obtain regulatory approvals where necessary

Maximum Potential GDPR Fine

Under GDPR, CNIL may impose fines up to:

20 million Euros or 4% of annual global turnover, whichever is higher.

Task 3.2: The Lawsuit (10 Points)

A class-action lawsuit has been filed in California on behalf of users whose data deletion requests were ignored.

4. **Question:** Under which California law (CCPA/CPRA) does this lawsuit fall? What specific "consumer right" has been violated?

ANSWER

The right violated right is the right to delete personal information

5. **Question:** What is a key difference between the private right of action in the CCPA/CPRA vs. the GDPR?

ANSWER

CCPA: Private lawsuits are generally limited to certain data breach situations involving inadequate security measures.

GDPR: Individuals can file complaints with regulators and may pursue compensation for broader privacy violations, including unlawful processing and denial of privacy rights.

Task 3.3: The Settlement Dilemma (5 Points)

The DOJ has begun investigating the bribery allegations in Brazil. They have offered GlobalSync a **Deferred Prosecution Agreement (DPA)**.

2. **Question:** What is a DPA, and what are the two key benefits for GlobalSync in accepting it?

ANSWER

A DPA is an agreement between prosecutors and a company where criminal charges are suspended while the organization fulfills specific compliance obligations.

KEY BENEFITS

- Avoidance of criminal conviction

- Reduced financial and reputational damage

3. **Question:** What is one major obligation the company will likely have to fulfill under this DPA?

ANSWER

GlobalSync will likely be required to:

- Implement a comprehensive compliance and anti-bribery monitoring program
- Cooperate with ongoing investigations
- Submit to independent compliance oversight or audits

Part 4: The Strategic Roadmap & Board Presentation (15 Points)

You have 10 minutes to present your findings and plan to the Board of Directors.

Task 4.1: The Remediation Plan (10 Points)

Create a **high-level Corrective Action Plan (CAP)** for the data subject request failure (Allegation C). Use the structure from the audit course:

- **Specific Action Items** (at least 3)
- **Assigned Department/Owner**
- **Target Completion Date** (set realistic deadlines)
- **Metric for Success** (How will you know it's fixed?)

ANSWER

ACTION ITEM	OWNER	TARGET COMPLETION	SUCCESS METRIC
Implement Automated DSR Portal	IT / Engineering	30 Days	0% overdue requests
Update Data Privacy Policy	Legal/GRC	15 Days	Board-approved policy
Staff Compliance Training	HR/CCO	45 Days	100% completion rate

Task 4.2: The "Tone at the Top" (5 Points)

In one paragraph, draft the opening statement for your Board presentation. Your goal is to convince them that compliance is not just a cost center but a strategic imperative for the company's future survival and the pending merger. Use language that demonstrates leadership commitment.

ANSWER

Members of the Board, the issues identified during this assessment demonstrate that compliance is not simply a regulatory obligation but a critical business function directly tied to GlobalSync's operational resilience, reputation, customer trust, and future growth. Our current compliance gaps expose the organization to significant financial penalties, legal liabilities, and merger-related risks. However, this moment also presents an opportunity to strengthen governance, modernize our compliance framework, and position GlobalSync as a trusted global technology leader. By investing in proactive compliance, privacy governance, and ethical business practices, we are not only protecting the organization from regulatory harm but also building long-term strategic value for shareholders, customers, and business partners

Bonus Challenge: The Future-Proofing Question (Extra 5 Points)

The Board is impressed but asks: "What one emerging trend in privacy or compliance should we invest in now to avoid such a crisis in the future?" Based on the "Future Trends" from your materials, recommend one trend (e.g., Privacy-Enhancing Technologies, AI Governance, Continuous Auditing) and briefly explain why it's a strategic investment for GlobalSync.

ANSWER

Recommended Trend: Continuous Auditing and Continuous Compliance Monitoring

GlobalSync should invest in continuous auditing technologies because they enable real-time monitoring of compliance risks, privacy obligations, and internal control failures.

Strategic Benefits

- Faster detection of compliance violations
- Improved regulatory reporting
- Automated monitoring of high-risk activities
- Enhanced audit readiness
- Better support for global privacy obligations

Continuous monitoring would help GlobalSync identify issues early before they escalate into regulatory crises or reputational damage